

# **ALLEGATO PRIVACY**

## **Accordo sul trattamento dei dati personali (Data Processing Agreement)**

ai sensi dell'art. 28 del Regolamento (UE) 2016/679 ("GDPR")

*Piattaforma NextSphere — Assistente digitale Lumo*

### **Sintesi in linguaggio semplice (non vincolante)**

Questa pagina riassume l'accordo per facilitarne la comprensione; in caso di contrasto prevale il testo delle clausole.

- Tu (la struttura) sei il "titolare" dei dati degli ospiti che usano Lumo: il chatbot lavora per te e per i tuoi ospiti.
- NextSphere tratta questi dati per tuo conto, come "responsabile", solo per far funzionare il servizio, secondo le regole scritte qui.
- Le conversazioni si cancellano automaticamente dopo 60 giorni. Per costruire la risposta il servizio interpella un fornitore esterno di intelligenza artificiale: gli invia il messaggio che l'ospite ha appena scritto, lo scambio immediatamente precedente e l'estratto delle informazioni che hai caricato tu, utile a rispondere; non riceve mai l'intera conversazione. La descrizione tecnica completa, che prevale in caso di divergenza, è al punto A.1. Se in quelle informazioni hai inserito il recapito di una persona, esce anche quello: tienilo presente nel decidere che cosa caricare.
- Nella tua dashboard puoi vedere estratti delle domande degli ospiti: usali solo per gestire l'ospitalità e i contenuti del chatbot.
- Per due attività NextSphere agisce invece in proprio, come "titolare autonomo": la sicurezza della piattaforma e il miglioramento del servizio (entro i 60 giorni, senza addestrare modelli di intelligenza artificiale). I dettagli sono nell'Allegato D.
- Devi informare i tuoi ospiti del trattamento: NextSphere ti fornisce un modello di informativa pronto all'uso.

### **1. Premesse e ambito di applicazione**

1.1. Il presente Allegato Privacy ("Accordo" o "DPA") disciplina il trattamento di dati personali che NextSphere effettua per conto del Cliente nell'ambito della fornitura della piattaforma NextSphere e dell'assistente digitale Lumo, ai sensi dell'art. 28 GDPR.

1.2. L'Accordo costituisce parte integrante e sostanziale delle Condizioni Generali di Abbonamento ("CG") ed è accettato contestualmente ad esse. In caso di contrasto,

per i soli profili di trattamento di dati personali per conto del Cliente prevale il presente Accordo (art. 19).

1.3. Per i trattamenti che NextSphere effettua quale titolare autonomo (art. 14 e Allegato D), il presente Accordo ha funzione ricognitiva e di delimitazione del perimetro; a tali trattamenti si applicano le rispettive informative privacy.

## **2. Definizioni**

2.1. I termini “trattamento”, “dato personale”, “titolare”, “responsabile”, “interessato”, “violazione dei dati personali” hanno il significato di cui all’art. 4 GDPR. “Cliente” o “Host”, “Fornitore” o “NextSphere”, “Lumo”, “Piattaforma”, “Ospite” o “Guest”, “Dashboard” hanno il significato attribuito nelle CG.

2.2. “Conversazioni”: i messaggi scambiati tra il Guest e Lumo, comprensivi dei metadati di cui all’Allegato A.

2.3. “Sub-responsabile”: il soggetto terzo di cui NextSphere si avvale per l’esecuzione di specifiche attività di trattamento per conto del Cliente, ai sensi dell’art. 28, par. 2 e 4, GDPR.

## **3. Ruoli delle parti**

3.1. Con riferimento al trattamento dei dati personali dei Guest e degli altri interessati connesso all’erogazione del servizio Lumo per la struttura del Cliente (Allegato A), il Cliente è titolare del trattamento e NextSphere è responsabile del trattamento ex art. 28 GDPR.

3.2. Il Cliente riconosce di determinare le finalità del trattamento (fornire assistenza informativa automatizzata ai propri ospiti) e di approvare, mediante l’accettazione del presente Accordo e la configurazione del servizio, i mezzi essenziali del trattamento come analiticamente descritti nell’Allegato A, ivi inclusi i tempi di conservazione, le categorie di destinatari e l’architettura del servizio.

3.3. Con riferimento ai trattamenti indicati nell’Allegato D (sicurezza della Piattaforma; miglioramento del servizio; gestione del rapporto contrattuale, pagamenti e adempimenti di legge), NextSphere agisce quale titolare autonomo del trattamento, nei limiti e con le garanzie ivi previste.

3.4. Le Parti si danno reciprocamente atto che il presente Accordo non istituisce alcuna contitolarità ai sensi dell’art. 26 GDPR e che ciascuna Parte risponde degli obblighi propri del rispettivo ruolo.

3.5. Ove il Cliente amministri strutture di terzi e, in relazione a esse, agisca a sua volta quale responsabile del trattamento designato dai rispettivi titolari, il presente Accordo vale quale contratto di sub-responsabilità ai sensi dell’art. 28, par. 4, GDPR:

NextSphere assume in tal caso la qualità di sub-responsabile e i riferimenti al Cliente quale titolare si intendono riferiti al titolare da questi rappresentato.

3.6. Gli obblighi assunti da NextSphere con il presente Accordo — istruzioni, riservatezza, misure di sicurezza, ricorso a sub-responsabili, assistenza, notifica delle violazioni, cancellazione e verifiche — sono identici nelle due configurazioni di cui ai commi 3.1 e 3.5. Muta esclusivamente il soggetto nei cui confronti tali obblighi sono dovuti, secondo quanto dichiarato e garantito dal Cliente ai sensi dell'art. 15.3.

#### **4. Oggetto, natura, durata e finalità del trattamento**

4.1. Oggetto e natura: raccolta, registrazione, organizzazione, conservazione, consultazione, elaborazione, estrazione in forma di statistiche, comunicazione ai destinatari autorizzati, cancellazione dei dati personali trattati tramite la Piattaforma e la superficie attraverso cui Lumo è raggiungibile, ossia il widget installato sul sito del Cliente, secondo il dettaglio dell'Allegato A.

4.2. Finalità: consentire il funzionamento di Lumo per la struttura del Cliente, la gestione delle sessioni dei Guest, la messa a disposizione del Cliente di estratti e statistiche, l'assistenza tecnica richiesta dal Cliente.

4.3. Durata: il trattamento ha durata pari a quella delle CG, fermi i termini di conservazione e cancellazione di cui agli artt. 17 e all'Allegato A.

#### **5. Istruzioni documentate del Titolare**

5.1. NextSphere tratta i dati personali esclusivamente sulla base delle istruzioni documentate del Cliente, costituite: (a) dal presente Accordo e dall'Allegato A, che il Cliente dichiara di aver esaminato e approvato quale descrizione analitica del funzionamento del servizio; (b) dalle configurazioni impostate dal Cliente tramite la Dashboard; (c) dalle richieste di assistenza inoltrate dal Cliente tramite i canali ufficiali. Non costituiscono istruzioni le richieste incompatibili con l'architettura standard del servizio.

5.2. Qualora NextSphere ritenga che un'istruzione violi il GDPR o altre disposizioni in materia di protezione dei dati, ne informa immediatamente il Cliente e può sospenderne l'esecuzione sino a chiarimento (art. 28, par. 3, ultimo comma, GDPR).

5.3. Eventuali trattamenti richiesti dal diritto dell'Unione o nazionale cui NextSphere è soggetta sono comunicati al Cliente prima del trattamento, salvo che la legge vieti tale informazione per rilevanti motivi di interesse pubblico.

#### **6. Categorie di interessati e di dati personali**

6.1. Interessati: Guest della struttura del Cliente; soggetti terzi eventualmente menzionati dai Guest nelle Conversazioni; referenti e collaboratori del Cliente i cui dati siano inseriti nei contenuti della struttura.

6.2. Dati personali: contenuto testuale delle Conversazioni, in quanto inserito liberamente dal Guest; metadati tecnici di sessione (identificativo di sessione associato all'identificativo della struttura, data e ora); lingua; dati eventualmente presenti nei contenuti della struttura riferiti a persone fisiche (contatti, numeri utili).

6.3. Il servizio è progettato per non richiedere ai Guest alcun dato identificativo e invita espressamente i Guest a non inserire dati personali non necessari. Le Parti si danno atto che i Guest potrebbero nondimeno inserire spontaneamente dati personali, anche appartenenti a categorie particolari ex art. 9 GDPR (ad esempio informazioni su salute, allergie o disabilità) o riferiti a minori: tali dati sono trattati nei soli limiti tecnici del funzionamento del servizio, con le misure di contenimento di cui all'Allegato A, e non sono in alcun caso utilizzati per le finalità di cui all'Allegato D, sezione 2, il cui perimetro non comprende il contenuto delle Conversazioni.

## **7. Obblighi generali del Responsabile**

7.1. NextSphere: (a) tratta i dati in conformità alle istruzioni ex art. 5; (b) garantisce gli impegni di riservatezza ex art. 8; (c) adotta le misure di sicurezza ex art. 9 e Allegato B; (d) rispetta le condizioni per il ricorso a Sub-responsabili ex art. 10; (e) assiste il Cliente ai sensi degli artt. 12 e 13; (f) procede alla cancellazione o restituzione ex art. 17; (g) mette a disposizione le informazioni ex art. 16.

7.2. NextSphere non vende i dati personali trattati per conto del Cliente né li utilizza per finalità proprie, fatti salvi i trattamenti a titolarità autonoma di cui all'Allegato D, nei limiti ivi definiti.

## **8. Persone autorizzate e riservatezza**

8.1. NextSphere garantisce che le persone fisiche autorizzate al trattamento (art. 29 GDPR; art. 2-quaterdecies d.lgs. 196/2003) si siano impegnate alla riservatezza o siano soggette ad adeguato obbligo legale di riservatezza, e che operino nei limiti delle istruzioni ricevute e dei profili di autorizzazione assegnati.

8.2. L'accesso in lettura al contenuto delle Conversazioni è consentito alle sole persone autorizzate, per le finalità di cui al presente Accordo e all'Allegato D, ed è oggetto di registrazione (log) secondo l'Allegato B.

## **9. Misure di sicurezza**

9.1. Tenuto conto dello stato dell'arte, dei costi di attuazione, nonché della natura, dell'oggetto, del contesto e delle finalità del trattamento e dei rischi per i diritti e le

libertà delle persone fisiche, NextSphere adotta le misure tecniche e organizzative di cui all'Allegato B, che il Cliente dichiara di aver esaminato e ritenuto adeguate ai sensi dell'art. 28, par. 1, GDPR.

9.2. NextSphere può aggiornare le misure dell'Allegato B in funzione dell'evoluzione tecnologica e dei rischi, senza ridurne il livello complessivo di protezione. Gli aggiornamenti sono resi disponibili tramite la Dashboard o il sito.

## **10. Sub-responsabili**

10.1. Il Cliente autorizza in via generale, ai sensi dell'art. 28, par. 2, GDPR, il ricorso da parte di NextSphere ai Sub-responsabili elencati nell'Allegato C per le categorie di servizi ivi indicate (hosting e infrastruttura; servizi di intelligenza artificiale; gestione dei consensi; servizi email e di dominio).

10.2. NextSphere impone a ciascun Sub-responsabile, mediante contratto, obblighi in materia di protezione dei dati sostanzialmente equivalenti a quelli previsti dal presente Accordo, restando pienamente responsabile verso il Cliente dell'adempimento degli obblighi dei Sub-responsabili (art. 28, par. 4, GDPR).

10.3. NextSphere comunica al Cliente ogni modifica prevista riguardante l'aggiunta o la sostituzione di Sub-responsabili, mediante aggiornamento dell'Allegato C e avviso tramite area riservata o posta elettronica, con un preavviso di almeno 15 giorni. Entro tale termine il Cliente può opporsi per motivi ragionevoli e documentati attinenti alla protezione dei dati; in difetto di soluzione condivisa entro 15 giorni dall'opposizione, il Cliente può recedere dalle CG limitatamente al servizio interessato, con effetto dalla data di efficacia della modifica, senza penali e con rimborso pro quota dei corrispettivi non goduti.

## **11. Trasferimenti verso Paesi terzi**

11.1. I dati trattati per conto del Cliente sono conservati su infrastruttura ubicata nello Spazio Economico Europeo (Allegato C).

11.2. Il fornitore di servizi di intelligenza artificiale è OpenAI Ireland Limited, stabilita nell'Unione europea: la trasmissione dei dati al medesimo non costituisce di per sé trasferimento verso un Paese terzo. Per gli eventuali trasferimenti successivi verso affiliate o terzi stabiliti fuori dallo Spazio economico europeo, l'accordo sul trattamento dei dati del fornitore prevede accordi contenenti le clausole contrattuali tipo adottate con decisione di esecuzione (UE) 2021/914 ovvero una decisione di adeguatezza ai sensi dell'art. 45 del Regolamento; NextSphere non è parte di tali accordi e ne dà indicazione al Cliente su richiesta, ai sensi dell'art. 28, par. 3, lett. h). Il fornitore tratta gli input trasmessi al modello e gli output generati al solo fine di erogare il servizio e secondo le istruzioni documentate, e non utilizza i dati ricevuti tramite interfaccia di programmazione, per impostazione predefinita, per

l'addestramento o il miglioramento dei propri modelli; NextSphere non ha aderito ad alcuna opzione che vi deroghi. I dati possono essere conservati dal fornitore per un periodo non superiore a trenta giorni per finalità di sicurezza e di prevenzione degli abusi, salvi gli obblighi di legge. Ove le garanzie vengano meno o siano sostanzialmente modificate, NextSphere ne informa il Cliente senza ritardo e sospende la trasmissione dei dati al fornitore fino al ripristino di una base di trasferimento conforme. L'attivazione di una configurazione che localizzi l'elaborazione dei dati nello Spazio economico europeo costituisce, per i fornitori indicati nell'Allegato C, un'ulteriore misura di riduzione del rischio attualmente allo studio da parte dei medesimi; il relativo stato è ivi riportato, fermo restando che la base giuridica del trasferimento resta in ogni caso quella indicata nello stesso Allegato C.

11.3. NextSphere informa il Cliente di ogni modifica sostanziale dei trasferimenti mediante aggiornamento dell'Allegato C secondo la procedura dell'art. 10.3.

11.4. Ove si renda necessario il trasferimento di dati personali verso Paesi terzi od organizzazioni internazionali per i quali la Commissione europea non abbia adottato una decisione di adeguatezza ai sensi dell'art. 45 GDPR, il trasferimento ha luogo soltanto in presenza di garanzie adeguate ai sensi dell'art. 46 GDPR, e a condizione che gli interessati dispongano di diritti effettivamente azionabili e di mezzi di ricorso effettivi. In mancanza di una decisione di adeguatezza ai sensi dell'art. 45 GDPR e di garanzie adeguate ai sensi dell'art. 46 GDPR, ivi comprese le norme vincolanti d'impresa, il trasferimento ha luogo soltanto ove ricorra una delle condizioni di cui all'art. 49 GDPR.

11.5. La disposizione che precede ha carattere generale e non deroga all'art. 10: il ricorso a un nuovo fornitore che tratti dati personali per conto del Cliente resta in ogni caso subordinato all'autorizzazione e alla procedura ivi previste, quale che sia il luogo del trattamento e quand'anche il trattamento avvenga in via meramente incidentale.

## **12. Assistenza al Titolare**

12.1. Tenuto conto della natura del trattamento, NextSphere assiste il Cliente con misure tecniche e organizzative adeguate, nella misura in cui ciò sia possibile, al fine di dare seguito alle richieste di esercizio dei diritti degli interessati (artt. 15-22 GDPR). Ove un interessato rivolga la richiesta direttamente a NextSphere, questa la inoltra al Cliente senza ingiustificato ritardo e comunque entro 5 giorni lavorativi, salvo che la richiesta riguardi trattamenti a titolarità autonoma di NextSphere.

12.2. La Piattaforma consente la ricerca e la cancellazione selettiva dei dati riferibili a una sessione, nei limiti tecnici descritti nell'Allegato A. Resta fermo che, per le richieste di interessati non identificati, trova applicazione l'art. 11 GDPR.

12.3. NextSphere assiste il Cliente nel garantire il rispetto degli obblighi di cui agli artt. 32-36 GDPR, tenendo conto della natura del trattamento e delle informazioni a propria disposizione; a tal fine mette a disposizione la documentazione descrittiva del servizio e, ove predisposta, la valutazione d'impatto di piattaforma in estratto.

### **13. Violazioni dei dati personali**

13.1. NextSphere informa il Cliente senza ingiustificato ritardo, e comunque entro 48 ore dal momento in cui ne è venuta a conoscenza, di ogni violazione dei dati personali che riguardi dati trattati per conto del Cliente, fornendo le informazioni di cui all'art. 33, par. 3, GDPR nella misura in cui siano ragionevolmente disponibili, anche in modo progressivo. Ove la violazione abbia origine presso il fornitore di servizi di intelligenza artificiale, il termine decorre dalla comunicazione di quest'ultimo, il quale è tenuto a informare senza ingiustificato ritardo e non entro un termine determinato.

13.2. Le eventuali notifiche all'autorità di controllo e comunicazioni agli interessati ex artt. 33-34 GDPR competono al Cliente quale titolare; NextSphere fornisce la ragionevole cooperazione necessaria e non effettua comunicazioni pubbliche riferite alla violazione senza previo coordinamento con il Cliente, salvi gli obblighi di legge propri.

### **14. Trattamenti a titolarità autonoma di NextSphere**

14.1. Le Parti si danno atto che NextSphere effettua, quale titolare autonomo, i trattamenti descritti nell'Allegato D, ossia: (a) sicurezza, monitoraggio e prevenzione degli abusi della Piattaforma; (b) miglioramento del servizio mediante analisi delle Conversazioni entro il termine di conservazione di 60 giorni, con esclusione di qualsiasi addestramento di modelli di intelligenza artificiale; (c) gestione del rapporto contrattuale, fatturazione e adempimenti di legge; (d) produzione e conservazione di statistiche aggregate secondo i criteri di anonimizzazione dell'Allegato D.

14.2. Tali trattamenti sono effettuati nel rispetto delle garanzie e dei limiti dell'Allegato D e delle informative rese agli interessati. Al di fuori di quanto previsto dall'Allegato D, ogni utilizzo dei dati trattati per conto del Cliente per finalità proprie di NextSphere è vietato (art. 28, par. 10, GDPR).

### **15. Obblighi del Cliente quale Titolare**

15.1. Il Cliente si impegna a: (a) rendere disponibile ai propri ospiti l'informativa privacy relativa ai trattamenti di propria titolarità, avvalendosi anche del modello messo a disposizione da NextSphere, e a non rimuovere né ostacolare la visualizzazione delle informative e degli avvisi presenti nell'interfaccia di Lumo; (b)

non utilizzare la Piattaforma per raccogliere dati personali non necessari, categorie particolari di dati, dati di pagamento o documenti di identità; (c) utilizzare gli estratti delle Conversazioni disponibili in Dashboard esclusivamente per la gestione dell'ospitalità e dei contenuti del servizio, quale titolare dei relativi trattamenti, astenendosi da usi ulteriori privi di idonea base giuridica; (d) mantenere riservate le credenziali di accesso e vigilare sui soggetti da esso autorizzati; (e) fornire istruzioni lecite; (f) inoltrare a NextSphere, senza ingiustificato ritardo, le richieste degli interessati eventualmente ricevute che riguardino i trattamenti a titolarità autonoma di NextSphere (Allegato D), in coerenza con quanto indicato nelle informative.

15.2. Il Cliente prende atto che l'eventuale riconduzione di una sessione a un ospite determinato, mediante informazioni nella propria disponibilità, costituisce trattamento di propria esclusiva titolarità, estraneo al presente Accordo.

15.3. Il Cliente dichiara e garantisce di rivestire la qualità di titolare del trattamento dei dati personali degli ospiti trattati tramite la Piattaforma ovvero, ove gestisca strutture di terzi, di essere stato debitamente autorizzato dal titolare a conferire a NextSphere l'incarico di cui al presente Accordo e ad autorizzare il ricorso a sub-responsabili ai sensi dell'art. 10. Il Cliente tiene indenne NextSphere dalle conseguenze pregiudizievoli derivanti dall'inesattezza di tale dichiarazione.

15.4. NextSphere non è tenuta a verificare la titolarità degli immobili né i rapporti intercorrenti tra il Cliente e i soggetti per conto dei quali questi eventualmente operi.

## **16. Audit e informazioni**

16.1. NextSphere mette a disposizione del Cliente tutte le informazioni necessarie per dimostrare il rispetto degli obblighi di cui all'art. 28 GDPR, in forma di documentazione scritta, certificazioni e attestazioni dei Sub-responsabili, sintesi delle misure di sicurezza e, ove disponibili, esiti di verifiche indipendenti.

16.2. Il Cliente può svolgere, direttamente o tramite un revisore indipendente non concorrente di NextSphere, verifiche ulteriori, previo preavviso scritto di almeno 30 giorni, per giustificato motivo, con modalità che non compromettano la sicurezza della Piattaforma né la riservatezza dei dati di altri clienti, durante il normale orario lavorativo e a proprie spese. Le verifiche da remoto su documentazione sono preferite ove idonee allo scopo.

## **17. Cessazione, cancellazione e restituzione**

17.1. Alla cessazione delle CG, per scelta del Cliente comunicata entro il termine di 30 giorni, NextSphere restituisce al Cliente i dati esportabili nei formati resi disponibili dalla Piattaforma e successivamente cancella i dati personali trattati per suo conto, ovvero procede direttamente alla cancellazione. In assenza di scelta, i dati sono cancellati decorsi 30 giorni dalla cessazione.



17.2. Restano esclusi dalla cancellazione i dati la cui conservazione è richiesta dal diritto dell'Unione o nazionale, nonché i dati trattati da NextSphere quale titolare autonomo ai sensi dell'Allegato D, nei limiti dei rispettivi termini di conservazione.

17.3. I dati cancellati dall'ambiente attivo possono permanere nei backup per il tempo massimo del ciclo di rotazione indicato nell'Allegato B, con accesso ristretto e al solo fine di continuità operativa, e sono sovrascritti al completamento del ciclo.

## **18. Responsabilità**

18.1. Ciascuna Parte risponde dei danni cagionati dal trattamento secondo il riparto di cui all'art. 82 GDPR. Eventuali limitazioni di responsabilità pattuite nelle CG non si applicano alla responsabilità verso gli interessati né alle sanzioni irrogate dalle autorità per violazioni imputabili alla Parte medesima.

## **19. Disposizioni finali**

19.1. Il presente Accordo ha la medesima durata delle CG e sopravvive alla loro cessazione per quanto necessario al completamento delle attività di cui all'art. 17.

19.2. Le modifiche al presente Accordo seguono la procedura di modifica delle CG, fermo quanto previsto dall'art. 10.3 per i Sub-responsabili. Per i profili di trattamento per conto del Cliente, il presente Accordo prevale sulle CG.

19.3. Legge applicabile e foro: come da CG, salve le norme inderogabili applicabili ai Clienti consumatori.

## **ALLEGATO A — Descrizione analitica del trattamento (istruzioni documentate)**

### **A.1 Architettura del servizio**

Il Guest accede a Lumo attraverso un'unica superficie: il widget installato sul sito del Cliente, raggiungibile anche mediante codice QR o collegamento diretto. Non è messa a disposizione dal Fornitore alcuna pagina autonoma di conversazione. L'accesso avviene senza registrazione né richiesta di dati identificativi. Il messaggio del Guest è trasmesso alla Piattaforma, ospitata su infrastruttura ubicata nello Spazio Economico Europeo, che genera la risposta anche mediante il fornitore di servizi di intelligenza artificiale indicato nell'Allegato C. La generazione della risposta si articola in due interrogazioni del fornitore di servizi di intelligenza artificiale indicato nell'Allegato C. Con la prima è trasmesso il messaggio che il Guest ha appena inviato, per la sua interpretazione e traduzione, unitamente allo scambio immediatamente precedente — la domanda anteriore e la risposta a essa data — ove esista, al solo fine di assicurare la continuità della conversazione. Non è trasmesso lo storico della Conversazione: il contesto è limitato a un unico scambio anteriore e non

si accumula al progredire del dialogo. Sulla base dell'interpretazione così ottenuta la Piattaforma reperisce dalla propria base di conoscenza, ospitata sull'infrastruttura di cui sopra, gli estratti dei contenuti informativi caricati dal Cliente pertinenti alla richiesta. Con la seconda interrogazione sono trasmessi tali estratti, unitamente al messaggio, per la composizione e la traduzione della risposta. Nel passaggio finale la Piattaforma indica al Guest i file locali eventualmente associati alle voci della base di conoscenza che hanno concorso alla risposta: tali file non sono trasmessi al fornitore. Gli estratti possono comprendere dati personali di persone fisiche diverse dal Guest, ove il Cliente li abbia inseriti nei propri contenuti informativi: si veda il punto A.6. L'interfaccia messa a disposizione del Guest accetta esclusivamente messaggi di testo: il Guest non può allegare alla Conversazione immagini, documenti o file di alcun genere. La facoltà di caricare file è riservata al Cliente. I contenuti informativi che il Cliente carica sulla Piattaforma, in formato PDF o immagine, concorrono alla generazione delle risposte e non costituiscono dati conversazionali.

## **A.2 Dati trattati e metadati**

Contenuto testuale delle Conversazioni; identificativo di sessione generato nell'ambito dell'identificativo della struttura; data e ora; lingua. Alle Conversazioni non sono associati indirizzi IP. Sul dispositivo del Guest è memorizzato un identificativo tecnico riferito alla struttura, che consente il recupero della conversazione: esso non è associato a dati identificativi del Guest, esso è denominato `ns_chat_` seguito dall'identificativo della struttura, ha durata di trenta giorni ed è facoltativo. Tali elementi sono comunicati al Cliente, con il Manuale Host, affinché ne dia conto nell'informativa sui cookie del proprio sito, di cui è titolare: il cookie è memorizzato dal widget installato sul sito del Cliente e non figura pertanto nell'informativa sui cookie del sito del Fornitore.

## **A.3 Conservazione**

Le Conversazioni e i relativi metadati sono cancellati automaticamente decorsi 60 giorni dalla loro generazione. I contenuti informativi caricati dal Cliente sono conservati per la durata del rapporto contrattuale, costituendo il contenuto del servizio. Ove il Cliente, quale titolare, abbia necessità di conservare una Conversazione oltre il termine di 60 giorni per l'accertamento, l'esercizio o la difesa di un diritto, provvede all'esportazione prima della scadenza ovvero ne richiede il congelamento selettivo, assumendone la responsabilità e la base giuridica. Le statistiche aggregate sopravvivono a tale termine nei soli limiti dei criteri di anonimizzazione di cui all'Allegato D. I log di sicurezza sono conservati secondo l'Allegato B.

## **A.4 Estratti in Dashboard**

Il Cliente può consultare in Dashboard, entro il termine di conservazione, estratti testuali delle richieste dei Guest e statistiche di utilizzo, per la gestione dell'ospitalità e dei contenuti del servizio.

### **A.5 Contenimento dei dati non necessari**

L'interfaccia invita i Guest a non inserire dati personali. I dati personali eventualmente inseriti spontaneamente, ivi inclusi quelli di cui all'art. 9 GDPR, non sono in alcun caso utilizzati per le finalità di miglioramento di cui all'Allegato D, che non hanno per oggetto il contenuto delle Conversazioni, e si estinguono con la cancellazione automatica di cui al punto A.3.

### **A.6 Dati personali di terzi contenuti nei contenuti informativi del Cliente**

I contenuti informativi che il Cliente carica sulla Piattaforma possono contenere dati personali di persone fisiche diverse dai Guest, quali manutentori, custodi, referenti condominiali o addetti della Struttura. Di tali dati il Cliente è titolare del trattamento. Ove compresi negli estratti pertinenti alla richiesta, essi sono trasmessi al fornitore di servizi di intelligenza artificiale secondo il punto A.1.

Non essendo raccolti presso l'interessato, a tali dati si applica l'art. 14 del Regolamento: il Cliente provvede all'informativa, salvo che ricorra una delle eccezioni del paragrafo 5 del medesimo articolo, e ne individua la base giuridica. Il Fornitore ne dà avviso al Cliente nel Manuale Host, affinché il Cliente ne tenga conto nel determinare quali contenuti caricare. Il Cliente resta libero di caricarli, assumendone la responsabilità quale titolare.

## **ALLEGATO B — Misure di sicurezza (sintesi)**

Cifratura del traffico in transito (TLS); autenticazione a più fattori richiesta a ogni accesso alla Piattaforma, sia degli amministratori sia del Cliente; segregazione logica dei dati per struttura con vincolo applicativo all'identificativo del tenant; registrazione degli accessi amministrativi e degli accessi al contenuto delle Conversazioni, con conservazione dei log per dodici mesi; backup cifrati, con copie giornaliere conservate sette giorni e copie settimanali conservate quattro settimane, e comunque con ciclo di rotazione non superiore a trentacinque giorni per i dati conversazionali, e procedura documentata di verifica del ripristino con cadenza almeno annuale; ambienti di sviluppo e collaudo separati dalla produzione, con impiego di soli dati sintetici o anonimizzati; limitazione degli accessi al principio del minimo privilegio; procedure di gestione delle violazioni; aggiornamento periodico delle componenti software.

I dati a riposo nella base di dati non sono cifrati a livello di servizio: la cifratura a riposo è attuata sulle copie di sicurezza. La valutazione al riguardo, condotta ai sensi

dell'art. 32, par. 1, del Regolamento e tenuto conto dello stato dell'arte e dei costi di attuazione, è documentata in apposito verbale datato, che costituisce allegato della policy di sicurezza interna del Fornitore ed è ivi richiamato al punto 7.2, ed è messa a disposizione del Cliente su richiesta. Il verbale indica gli scenari che la misura presidierebbe, le misure che concorrono nel frattempo e le circostanze al verificarsi delle quali la valutazione è riesaminata.

Concorre alla protezione dei dati conversazionali una misura di minimizzazione attuativa degli articoli 5, paragrafo 1, lettera c), e 25, paragrafi 1 e 2, del Regolamento, che il Cliente può considerare nella propria valutazione ai sensi dell'art. 28, paragrafo 1: sulle domande relative a intolleranze, allergie, accessibilità e condizioni di salute l'Assistente restituisce le sole informazioni generali caricate dal Cliente e rinvia l'Ospite alla Struttura, senza sollecitare né richiedere la condizione personale dell'Ospite. Essa è dichiarata agli Ospiti nella Privacy Policy Guest e nei Termini di utilizzo dell'Assistente, e sono presupposto del divieto contrattuale di cui all'articolo 18, comma 1, delle Condizioni Generali.

Le misure sono attuate secondo la policy di sicurezza interna adottata da NextSphere. L'aggiornamento di tale policy non può in alcun caso ridurre il livello di protezione descritto nel presente Allegato, che costituisce il livello minimo garantito al Cliente e resta modificabile soltanto nei termini dell'art. 9.2. Su richiesta del Cliente, NextSphere mette a disposizione una sintesi aggiornata e datata delle misure vigenti.

### **ALLEGATO C — Elenco dei Sub-responsabili autorizzati**

| <b>Sub-responsabile</b>                                                                                                                | <b>Servizio</b>                                                                                            | <b>Luogo del trattamento</b>                  | <b>Trasferimenti / garanzie</b>                                                                                                                                                                                                                                                                      |
|----------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| OVH SAS (partita IVA FR22424761419), 2 rue Kellermann, 59100 Roubaix, Francia                                                          | Hosting e infrastruttura                                                                                   | Spazio economico europeo                      | Trattamento nel SEE; per eventuali trattamenti in Paesi terzi, clausole contrattuali tipo (dec. esec. UE 2021/914) o decisione di adeguatezza ex art. 45                                                                                                                                             |
| OpenAI Ireland Limited (n. reg. 737350), 1st Floor, The Liffey Trust Centre, 117-126 Sheriff Street Upper, Dublin 1, D01 YC43, Irlanda | Interpretazione e traduzione del messaggio del Guest; composizione e traduzione della risposta (punto A.1) | Irlanda; possibili trattamenti in Paesi terzi | Controparte contrattuale stabilita nell'Unione europea: la trasmissione non costituisce trasferimento verso un Paese terzo. Per gli eventuali trasferimenti successivi, clausole contrattuali tipo (dec. esec. UE 2021/914) o decisione di adeguatezza ex art. 45, secondo il § 4.1 dell'accordo sul |

|                                                                                                                   |                                                                                                                                                                          |                                      |                                                                                                                                                                                                                                     |
|-------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                   |                                                                                                                                                                          |                                      | trattamento dei dati del fornitore. Attivazione della residenza dei dati nell'Unione europea allo studio quale ulteriore misura di riduzione del rischio, senza incidenza sulla validità della base di trasferimento sopra indicata |
| Aruba S.p.A.,<br>Bibbiena (AR), Italia                                                                            | Servizi email e dominio                                                                                                                                                  | Italia/SEE                           | —                                                                                                                                                                                                                                   |
| CookieBot —<br>Usercentrics A/S<br>(partita IVA<br>DK34624607),<br>Havnegade 39, 1058<br>Copenhagen,<br>Danimarca | Gestione consensi e storage tecnico                                                                                                                                      | Danimarca — Spazio economico europeo | Trattamento nel SEE; per eventuali trattamenti in Paesi terzi, clausole contrattuali tipo (dec. esec. UE 2021/914) o decisione di adeguatezza ex art. 45                                                                            |
| Aftene Gicu, partita IVA 04785910276,<br>Via Monte Nero 20,<br>30171 Mestre (VE)                                  | Sviluppo, manutenzione e assistenza tecnica; accesso occasionale su autorizzazione. Le funzioni di amministrazione di sistema sono esercitate direttamente da NextSphere | Italia                               | —                                                                                                                                                                                                                                   |

Non operano quali sub-responsabili, e non figurano pertanto nel presente elenco: il prestatore di servizi di pagamento, che opera nell'ambito dei trattamenti di titolarità di NextSphere per la gestione dei pagamenti del Cliente e, per i servizi di pagamento regolamentati, quale autonomo titolare, come indicato nell'informativa privacy per le strutture ricettive; i consulenti fiscali e legali, che trattano dati quali titolari autonomi nell'ambito dei rispettivi incarichi professionali e degli obblighi di legge propri.

Il presente Allegato costituisce l'elenco dei sub-responsabili autorizzati ai fini dell'autorizzazione generale di cui all'art. 10.1 e reca la data di ultima modifica indicata in calce al presente Accordo. Ogni sua variazione segue la procedura dell'art. 10.3 e resta consultabile dal Cliente nell'area riservata, unitamente alla versione da lui accettata e alla data di accettazione. Non sono altrove pubblicati elenchi difformi.

## **ALLEGATO D**

## **Trattamenti a titolarità autonoma di NextSphere: perimetro e garanzie**

### **D.1 Sicurezza e prevenzione abusi**

Trattamento di log tecnici, metadati e, ove strettamente necessario, contenuti delle Conversazioni per finalità di sicurezza, monitoraggio, prevenzione di abusi e malfunzionamenti. Base giuridica: legittimo interesse (art. 6, par. 1, lett. f), GDPR; considerando 49).

### **D.2 Miglioramento del servizio**

Miglioramento del servizio svolto esclusivamente su informazioni generate automaticamente nel corso dell'erogazione, che non comprendono il contenuto delle Conversazioni. Il contenuto delle Conversazioni non è oggetto del presente trattamento e non è ad esso trasmesso: ove le informazioni impiegate risultino da una elaborazione del contenuto, tale elaborazione avviene all'interno dell'erogazione del servizio, di titolarità del Cliente, e al trattamento di titolarità di NextSphere accede soltanto il suo esito, privo del testo. La descrizione tecnica delle informazioni effettivamente impiegate è resa dal responsabile del trattamento nell'attestazione delle misure di sicurezza ed è messa a disposizione del Cliente su richiesta. Garanzie: (a) esclusione di qualsiasi addestramento, affinamento o riaddestramento di modelli di intelligenza artificiale; (b) accessi limitati alle persone autorizzate e registrati; (c) esclusione strutturale del contenuto delle Conversazioni dal perimetro del trattamento, in luogo del mascheramento; (c-bis) verifica periodica dell'effettiva non riconducibilità delle riformulazioni a Ospiti determinati, secondo il criterio applicato alle statistiche aggregate; (d) divieto di estrazione delle Conversazioni in chiaro al di fuori dell'ambiente di produzione; (e) diritto di opposizione dell'interessato ai sensi dell'art. 21 GDPR, segnalato nell'informativa. Base giuridica: legittimo interesse, come da valutazione documentata (LIA).

Ogni futura estensione del presente trattamento al contenuto delle Conversazioni richiederebbe il consenso esplicito dell'Ospite ai sensi dell'art. 9, par. 2, lett. a), GDPR, non essendo il legittimo interesse fra le condizioni ivi previste. Tale consenso, ove introdotto, sarà richiesto a conversazione conclusa, con comando di rifiuto equivalente, esclusione per impostazione predefinita delle conversazioni non consentite e mezzo di revoca reso disponibile all'Ospite nel momento stesso della prestazione. L'estensione costituisce modifica sostanziale e comporta il riesame della valutazione d'impatto.

### **D.3 Accesso a singole Conversazioni per assistenza e diagnosi: perimetro distinto**

Resta distinto dai trattamenti di cui alle sezioni D.1 e D.2 l'accesso a una singola Conversazione determinata, effettuato su richiesta del Cliente, per dare seguito a

una richiesta dell'interessato ovvero per la diagnosi di un malfunzionamento segnalato e non riproducibile con dati di prova. Tale accesso costituisce attività di erogazione del servizio, svolta per conto del Cliente ai sensi dell'art. 28 GDPR e su sua istruzione, è consentito nei soli casi e con le modalità previsti dal registro degli accessi alle Conversazioni, ed è in ogni caso motivato e registrato.

La correzione del malfunzionamento accertato in tale sede è parte della medesima attività, e vi rientra la modifica delle istruzioni di sistema, dei contenuti di configurazione e del codice dell'applicazione che ne consegue: rileva la ragione dell'accesso, non la forma tecnica del rimedio. Non è invece consentito l'accesso a Conversazioni in assenza di un segnale specifico che lo giustifichi. Costituiscono segnale idoneo la segnalazione del Cliente o dell'interessato, l'incidente di sicurezza e l'evento di mancata risposta registrato dal sistema, il cui identificativo vale quale riferimento ai fini del registro degli accessi. Non costituiscono segnale idoneo la verifica generale della qualità delle risposte, il campionamento e l'esame di Conversazioni che non presentino alcuna anomalia rilevata: tali attività ricadono nella sezione D.2 e si svolgono sulle sole informazioni ivi indicate. Il criterio distintivo è che si accede perché qualcosa non ha funzionato, e non per osservare che cosa gli Ospiti scrivano.

L'accesso consentito ai sensi della presente sezione avviene, per impostazione predefinita, su una rappresentazione della Conversazione nella quale i dati identificativi e le informazioni appartenenti alle categorie particolari di cui all'art. 9 GDPR sono sostituiti da contrassegni. La visualizzazione del testo integrale resta possibile ove necessaria alla diagnosi, ma costituisce accesso ulteriore e distinto, registrato come tale con indicazione della ragione.

La rappresentazione contrassegnata non costituisce dato anonimo, essendo il testo integrale ricostruibile, e non è pertanto impiegabile per le finalità di cui alla sezione D.2, il cui perimetro resta quello ivi definito.

#### **D.4 Statistiche aggregate**

Produzione e conservazione di statistiche prive di riferimenti a persone identificabili. Criteri: aggregazione su soglie minime idonee a impedire la riconduzione a singoli interessati anche da parte del Cliente; esclusione di riproduzioni testuali delle Conversazioni oltre il termine di conservazione.

#### **D.5 Gestione contrattuale e obblighi di legge**

Trattamenti relativi ad account, corrispettivi, fatturazione, assistenza e adempimenti fiscali, secondo la Privacy Policy Host.

Luogo: Mestre. La data e l'ora dell'accettazione del presente Accordo sono registrate dalla Piattaforma e risultano dalla cronologia contrattuale dell'area riservata del Cliente.

Il Cliente (accettazione mediante flag dedicato in fase di attivazione, registrata con marca temporale) — NextSphere

Versione 1.0 — 1 settembre 2026